Méthodes d'audit IoT fondées sur les preuves

Sept familles pour rendre LANCE plus utile à l'auditeur

Projet LANCE
Recherche exploratoire assistée par Codex

Dernière révision : 2026-10-07 13:49
(Europe/Brussels, UTC+02:00)

Statut : revue ciblée et protocole proposé ; aucun gain mesuré

Résumé

Cette étude examine comment enrichir un audit de dispositifs de l'Internet des objets (IoT) par la qualité de ses conclusions : propriétés explicites, preuves traçables, contradictions et limites observables. Une lecture ciblée de sources primaires distingue sept familles complémentaires : couverture normative, provenance, argumentation d'assurance, comparaison de propriétés, applicabilité d'avis de sécurité, synthèse citée et revue indépendante. La proposition prioritaire associe provenance et arguments de preuve à une rédaction fondée sur un dossier figé. Sa question scientifique est de déterminer si cette combinaison réduit les conclusions excessives et le temps de relecture, à observations identiques. Aucun audit réseau, essai de laboratoire ni reproduction d'article n'a été exécuté. Les coûts et valeurs présentés sont des appréciations de conception, non des résultats expérimentaux ; les standards cités ne constituent pas une certification de LANCE.

Table des matières

1 Objectif, périmètre et méthode **2**

2 Constats : sept familles complémentaires **2**

3 Comparaison et décision proposée **5**

4 Protocole proposé et mesures **6**

5 Discussion et limites **6**

6 Conclusion et prochaines étapes **6**

Références et profondeur de lecture **7**

Lecture. Les références donnent les versions choisies, les liens primaires et les passages effectivement exploités. Les propositions pour LANCE restent distinctes des faits bibliographiques et de la documentation du système implémenté.

1 Objectif, périmètre et méthode

Question proposée. À dossier d'observations constant, relier chaque conclusion à une propriété, une portée, des preuves et des contre-preuves permet-il de diminuer les erreurs de restitution sans masquer les lacunes de couverture ?

La recherche existante du 27 septembre 2026 pose la comparaison D1/A1, règles conditionnelles contre politique à modèle de langage (LLM), avec coûts et preuves communs. Son état de l'art couvre déjà les agents de pentest et leurs benchmarks [1]. Le présent rapport développe une question distincte : l'assurance des conclusions et l'utilité de la restitution, même lorsque la collecte demeure identique. Il prolonge D1-R, variante déjà proposée où un LLM rédige le rapport à partir des seuls artefacts de D1 ; il ne remplace pas l'étude D1/A1 et ne revendique aucune première mondiale.

Périmètre. L'audit porte ici sur des documents, configurations, inventaires et observations fournis par le propriétaire, ainsi que sur des dossiers synthétiques locaux contrôlés. La revue ne propose pas de procédure d'exploitation, de reproduction de CVE ou d'intrusion. Aucun code applicatif n'est modifié. Le homelab personnel demeure hors du périmètre du dépôt.

Méthode. Les index `research/README.md` et `docs/README.md`, l'état de l'art D1/A1 et `src/agent/phases/README.md` ont été lus le 7 octobre 2026. Cette dernière page décrit six phases ; sa lecture documentaire ne prouve pas la conformité du code ni l'état d'un déploiement. La revue bibliographique, consultée à cette même date, utilise les documents NIST, ETSI, W3C, OMG et OASIS ainsi que trois articles d'origine. Les requêtes visent capacités IoT, provenance, assurance, propriétés d'autorisation et citations LLM. Les notices vérifient les dates et les versions ; les sections sélectionnées fondent les constats. Il s'agit d'une sélection orientée par la question, sans protocole exhaustif de revue systématique.

2 Constats : sept familles complémentaires

1. Couverture normative et applicabilité

Fait sourcé. NISTIR 8259A définit des capacités techniques comme la configuration et la restriction des interfaces aux entités autorisées ; son socle nécessite une adaptation au contexte [2]. ETSI EN 303 645 V3.1.3 vise l'IoT grand public et distingue exigences et recommandations. Sa clause 4 renvoie à TS 103 701 pour l'évaluation, au lieu de définir elle-même une méthode de test [3, 4].

Proposition LANCE. Construire une matrice « exigence ou capacité / justification d'applicabilité / observation disponible / conclusion limitée ». Conserver les états non applicable, non observé et inconclusif. Une interface réseau silencieuse ne renseigne pas à elle seule le stockage des secrets ou le cycle de mise à jour. L'intérêt est de montrer ce qui manque, pas seulement les écarts détectés. L'adaptation à une smart city doit être motivée dispositif par dispositif.

2. Provenance des observations et des transformations

Fait sourcé. PROV-DM distingue entités, activités, agents responsables et dérivations [5].
Proposition LANCE. Relier l'artefact brut, sa normalisation, la conclusion et sa révision, avec identifiant de dossier, date, version du producteur et empreinte. Un extrait perdant son contexte doit rester une dérivation consultable. Une empreinte détecte une modification relative à une valeur de référence ; elle ne prouve ni l'identité du dispositif, ni la véracité de l'observation. Cette famille facilite la relecture et la comparaison temporelle, sans augmenter à elle seule la couverture.

3. Argumentation d'assurance : conclusion, preuve, objection

Fait sourcé. Structured Assurance Case Metamodel (SACM) 2.3 formalise les affirmations, les références aux artefacts et leurs relations argumentatives. Les déclarations distinguent notamment hypothèse, besoin de support et affirmation réfutée [6]. Le métamodèle exprime un argument ; il n'en garantit pas la validité.

Proposition LANCE. Introduire un dossier d'argumentation léger : propriété visée, contexte, conclusion, éléments de soutien, éléments contradictoires, hypothèses et portée. Exemple purement documentaire : « le contrôle d'accès attendu est présent dans la configuration exportée C » est plus précis que « le dispositif est sécurisé ». Si C est incomplet ou plus ancien que le déploiement, le dossier garde une limite explicite. L'auditeur doit pouvoir contester une inférence sans supprimer l'observation initiale.

Cette représentation rend l'incertitude exploitable. Une conclusion peut être soutenue, contredite ou insuffisamment étayée, tandis que la couverture reste une dimension distincte. L'absence de contre-preuve n'est pas une preuve universelle. Un modèle peut proposer le lien argumentatif ; un validateur structurel peut vérifier les références et les champs requis. La force sémantique de l'inférence exige encore une revue compétente. La priorité concerne quelques propriétés précises, avec un format compréhensible, avant une interopérabilité SACM complète.

4. Propriétés d'autorisation et configurations comparées

Fait sourcé. NIST SP 800-53A sépare examen, entretien et test ; le test compare un état observé à un état attendu sous conditions définies [7]. L'article Cedar de FSE Companion 2024 associe modèle exécutable, propriétés prouvées et comparaison du comportement de l'implémentation avec celui du modèle [8]. Cette assurance de logiciel ne prouve pas la sécurité d'un équipement IoT.

Proposition LANCE. Décrire hors ligne une propriété d'autorisation fournie par le propriétaire, puis comparer sa représentation attendue à des exports ou à un évaluateur local. Les contrôles appariés peuvent présenter deux configurations dans des dossiers synthétiques contrôlés dont seule une propriété déclarée change ; le dossier doit identifier ce changement et limiter sa conclusion à ce qu'il observe. Une seconde représentation indépendante aide à découvrir un défaut du parseur ou de l'oracle, plutôt qu'une faille du dispositif.

Pour une relation métamorphique, une transformation neutre définie au préalable, telle que le réordonnancement d'entrées dont la sémantique est indépendante de l'ordre, devrait laisser la conclusion inchangée. C'est une hypothèse de conception pour LANCE, pas un résultat du papier Cedar. Une transformation qui modifie la sémantique ou une propriété mal formalisée invalide le contrôle. Le rapport doit distinguer erreur d'extraction, désaccord d'oracles, violation de propriété et donnée insuffisante.

Intérêt et limite communs. Les familles 3 et 4 rapprochent l'audit des exigences du propriétaire. Leur valeur dépend de spécifications fiables, versionnées et suffisamment précises. Aucun mécanisme décrit ici n'infère automatiquement une politique métier correcte à partir d'un résultat réseau.

5. Applicabilité d'avis de sécurité à un inventaire fourni

Fait sourcé. Common Security Advisory Framework (CSAF) 2.0 représente les produits, les vulnérabilités, les statuts d'affectation et les remédiations. Les statuts distinguent entre autres affecté, non affecté, corrigé et sous investigation ; certaines justifications sont représentables dans les indicateurs utilisés par Vulnerability-Exploitability eXchange (VEX) [9].

Proposition LANCE. Rapprocher un inventaire ou une nomenclature logicielle fourni du document constructeur, en gardant l'identité exacte du composant, la version, l'émetteur et la date de l'avis. Documenter séparément le rapprochement de version et les hypothèses de configuration. Une correspondance approximative ne devient pas une vulnérabilité confirmée ; une déclaration constructeur non affecté ne prouve pas que l'instance locale correspond aux préconditions invoquées.

Cette famille enrichit les priorités de maintenance et les demandes d'information. Elle ne nécessite pas d'exécuter un exploit. Ses limites sont les inventaires incomplets, les composants embarqués non identifiés, les avis absents ou périmés et les identifiants ambigus. Le rapport cite une version figée de CSAF 2.0 ; il n'a pas examiné les évolutions de CSAF 2.1.

6. Synthèse LLM avec citations d'artefacts

Fait sourcé. ALCE évalue la qualité de réponses documentaires selon plusieurs dimensions et sépare la couverture des affirmations par leurs citations de la pertinence de ces citations. Son appréciation automatique utilise un modèle d'inférence textuelle, confronté à une évaluation humaine [10]. Les questions ouvertes de ce benchmark ne sont pas des audits IoT.

Proposition LANCE. Restreindre le rédacteur à un dossier de preuves figé, attribuer une référence consultable à chaque affirmation technique, puis vérifier mécaniquement l'existence des références et la présence de la portée. Les extraits doivent conserver les conditions nécessaires et les contradictions. Le texte reçu est une donnée à analyser ; il ne définit pas les consignes du rédacteur.

La mesure utile porte sur les affirmations effectivement soutenues, pas sur le nombre de liens imprimés. Une citation correcte peut accompagner une inférence incorrecte. Un score sémantique automatique reste un indicateur de triage ; un lecteur expert apprécie la solidité des conclusions. Le protocole isole ainsi un bénéfice de restitution éventuel, sans le présenter comme une nouvelle détection.

7. Révision structurée et relecture indépendante

Fait sourcé. Huang et al. étudient l'auto-correction intrinsèque du raisonnement sans retour externe et observent des limites sur leurs tâches et modèles [11]. Ce résultat de 2024 ne justifie pas une conclusion universelle sur tous les modèles de 2026.

Proposition LANCE. Donner au relecteur une grille explicite : fidélité aux preuves, contre-preuves oubliées, confusion entre propriété locale et sécurité globale, avis constructeur et instance locale, absence de donnée et verdict négatif. Prévoir un retour aux preuves et un droit d'abstention. Un second modèle peut suggérer des objections, mais son accord n'est pas une validation indépendante ; les erreurs peuvent être corrélées. Pour l'évaluation, des experts distincts et une adjudication documentée forment la référence.

3 Comparaison et décision proposée

Le tableau 1 compare les familles pour un premier incrément documentaire et hors ligne. Le coût désigne l'effort relatif d'intégration et d'entretien ; il ne représente ni une durée ni un prix observé. L'observabilité décrit ce qui serait vérifiable dans les livrables. Les appréciations sont celles de cette étude, sans pondération chiffrée ni classement expérimental.

Famille	Coût relatif	Observabilité et valeur attendue	Limite déterminante
1. Couverture normative	Moyen	Matrice, conditions d'applicabilité et inconnus ; lisibilité de couverture	Exigences internes souvent non observables à distance
2. Provenance	Faible à moyen	Dérivations, versions et traces ; relecture et comparaison	Ne garantit pas la vérité des données
3. Assurance	Moyen	Argument, hypothèses et objections ; maîtrise de la portée	Argument plausible mais invalide
4. Propriétés comparées	Moyen à élevé	Attendu/observé, dossiers contrôlés et écarts ; contrôles reproductibles	Qualité de l'oracle et de la spécification
5. Avis et inventaire	Moyen	Correspondances, avis datés et réserves ; maintenance contextualisée	Identité/version/configuration incomplètes
6. Synthèse citée	Moyen	Affirmations et sources ; restitution consultable	Soutien sémantique et conditions mal restitués
7. Revue indépendante	Moyen à élevé	Objections et adjudications ; erreurs décelées	Temps humain et corrélation des modèles

TABLE 1 – Appréciations de conception pour LANCE, sans mesure expérimentale. Les familles sont combinables.

Priorité proposée : provenance + argumentation + synthèse citée. Les familles 2, 3 et 6 partagent un objet stable : un dossier d'observations. L'incrément pourrait ajouter un index de preuves et un format de conclusions bornées, puis une génération de rapport et sa revue. Le collecteur conserve son périmètre. Cela rend la proposition évaluable sur des artefacts déjà disponibles, sans dépendre d'un nouveau contrôleur de collecte.

La famille 1 fournit des propriétés initiales et leurs limites d'observabilité. La famille 7 fournit un mode d'évaluation, pas une promesse de fiabilité. Les familles 4 et 5 deviennent des extensions distinctes lorsque le propriétaire peut fournir une politique ou un inventaire de qualité. Une exigence non observable est une demande d'information justifiée, pas une raison d'inventer une preuve.

Objet de sortie proposé. Une entrée associerait identifiant de propriété, portée, observations référencées, conclusion bornée, hypothèses, contradiction éventuelle, statut et date. L'index enregistrerait les dérivations et versions. Aucun de ces champs ne devient une nouvelle métrique de conformité sans contrat de référence validé. Les décisions d'implémentation et de compatibilité restent à établir dans les modules propriétaires.

4 Protocole proposé et mesures

Étude hors ligne, non exécutée. Constituer des dossiers de configurations et d'observations contrôlées avec vérité de référence tenue hors des données accessibles aux rédacteurs. Inclure des propriétés respectées, des écarts connus, des données incomplètes et des contradictions. L'absence de réponse et les documents périmés doivent pouvoir conduire à inconclusif. Les dossiers sains sont indispensables pour observer les conclusions excessives.

Comparer successivement une restitution structurée déterministe, un rédacteur LLM sur le même dossier brut et un rédacteur LLM sur le même dossier muni de l'index et des arguments. Garder le modèle et le budget comparables pour isoler l'effet du format. Une ablation retirant l'argumentation mais conservant l'index sépare la provenance de l'assistance sémantique. L'index produit par une règle commune peut contenir des erreurs ; celles-ci restent visibles dans la référence et le bilan.

Mesures proposées. Faire annoter à l'aveugle les affirmations techniques : soutenues, contredites ou non déterminables, avec une règle d'annotation fixée avant le test. Mesurer la proportion de conclusions dépassant leurs preuves, la proportion d'affirmations correctement étayées, les lacunes signalées à bon escient et les contradictions omises. Rapporter les nombres absolus et les dénominateurs ; un texte très court ne doit pas gagner en supprimant les conclusions utiles. Compter le temps de relecture et de correction, les coûts de génération, les abstentions injustifiées et les erreurs de références.

Deux experts annotent un sous-ensemble commun ; les désaccords et leur adjudication sont conservés. La présentation et l'ordre des variantes sont masqués ou randomisés autant que possible. Séparer les dossiers de développement des familles de test, geler règles, prompts et versions, puis calculer des écarts appariés. Les répétitions d'un même dossier synthétique contrôlé ne sont pas des familles indépendantes. Le nombre de dossiers et le gain minimal utile nécessitent un pilote ; aucun effectif ou seuil favorable n'est présupposé.

5 Discussion et limites

La revue ne fournit aucune mesure de gain pour LANCE. Les coûts du tableau sont des estimations qualitatives. Les standards IoT grand public ne suffisent pas à établir une conformité industrielle, médicale ou réglementaire d'une smart city. Les expériences Cedar assurent un langage et son implémentation ; ALCE évalue des citations documentaires. Leur transfert à l'audit est une hypothèse à tester.

La provenance peut conserver une erreur fidèlement. Un graphe d'assurance peut rendre un mauvais raisonnement plus convaincant. Une relecture LLM peut reproduire une erreur de son auteur. Les versions récentes des modèles, l'état du laboratoire et les artefacts d'exécution n'ont pas été évalués. Le présent document ne conclut ni sur la détection réseau, ni sur l'efficacité d'une intrusion, ni sur le bénéfice de D1/A1.

6 Conclusion et prochaines étapes

La contribution la plus défendable serait une mesure de la qualité des conclusions à preuves constantes : fidélité, portée, inconnus et coût de relecture. Commencer par quelques dossiers contrôlés, une référence déterministe sérieuse et une annotation indépendante permettrait d'éprouver la proposition. Un résultat sans gain resterait utile pour décider où réserver le LLM. La mise en production et la promotion dans `docs/` exigeraient ensuite une validation propre au comportement retenu.

Références et profondeur de lecture

[1] Projet LANCE. *Agent / automatisation*, dossier du 2026-09-27 ; état de l'art daté du 2026-09-28, rapport révisé le 2026-10-01. Lecture du README et de l'état de l'art complet, ainsi que des index et de la page du pipeline, le 2026-10-07 ; aucune nouvelle validation de code. Source locale : état de l'art D1/A1.

[2] M. Fagan et al., NIST. *NISTIR 8259A, IoT Device Cybersecurity Capability Core Baseline*, mai 2020, version finale. Notice, introduction et section 2, tableau des capacités : lecture ciblée de configuration et contrôle des interfaces ; pas de reproduction. https://doi.org/10.6028/NIST.IR.8259A

[3] ETSI. *EN 303 645 V3.1.3*, septembre 2024. Notice de publication, clause 4, extraits 5.1 et 5.4, aperçu de l'annexe B ; lecture partielle, pas d'évaluation de conformité. https://www.etsi.org/deliver/etsi_en/303600_303699/303645/03.01.03_60/en_303645v030103p.pdf

[4] ETSI. *TS 103 701 V2.1.1*, mai 2025. Notice, définitions ICS/IXIT et aperçu méthodologique 4.1 ; les procédures fonctionnelles détaillées n'ont pas été évaluées ni exécutées. https://www.etsi.org/deliver/etsi_ts/103700_103799/103701/02.01.01_60/ts_103701v020101p.pdf

[5] L. Moreau et P. Missier (dir.), W3C. *PROV-DM*, recommandation du 30 avril 2013. Résumé et structures centrales, section 2.1 ; contraintes et conformité d'un export LANCE non étudiées. https://www.w3.org/TR/2013/REC-prov-dm-20130430/

[6] OMG. *Structured Assurance Case Metamodel 2.3*, adoption octobre 2023, identifiant formal/23-05-08. Notice et extraits 11.8–11.12 ; exemples de réfutation dans l'annexe D. Aucune implémentation conforme reproduite. https://www.omg.org/spec/SACM/2.3/

[7] Joint Task Force, NIST. *SP 800-53A Rev. 5*, janvier 2022. Notice consultée, qui signale Release 5.2.0 du 2025-08-27 ; lecture ciblée de la méthodologie 2.4 du PDF Rev. 5. Catalogue détaillé et changements de 5.2.0 non audités. https://csrc.nist.gov/pubs/sp/800/53/a/r5/final

[8] C. Disselkoen et al. *How We Built Cedar : A Verification-Guided Approach*, FSE Companion 2024 ; copie auteurs arXiv v1 du 2024-07-01. Introduction, principe modèle/implémentation et extraits 4.2–4.3 ; aucune reproduction, aucun transfert de performance revendiqué. https://arxiv.org/html/2407.01688v1

[9] L. Rock, S. Hagen et T. Schmidt (dir.), OASIS. *CSAF 2.0*, standard du 2022-11-18. Résumé et sections 3.2.3.5 et 3.2.3.9 ; lecture ciblée des indicateurs et statuts, version 2.1 non étudiée. https://docs.oasis-open.org/csaf/csaf/v2.0/os/csaf-v2.0-os.html

[10] T. Gao et al. *Enabling Large Language Models to Generate Text with Citations*, EMNLP 2023, pp. 6465–6488. Notice, résumé et section 3.3 ; évaluation humaine consultée par extraits, protocoles et scores non reproduits. https://aclanthology.org/2023.emnlp-main.398/

[11] J. Huang et al. *Large Language Models Cannot Self-Correct Reasoning Yet*, ICLR 2024, version publiée. Résumé, introduction et extraits de discussion du retour externe ; expériences et versions 2026 des modèles non reproduites. https://openreview.net/forum?id=IkmD3fKBPQ